

AI Governance & Incident Assistant — Architecture Document

Project status:

Phase 1 — Foundation

Author:

T1N0

Last updated:

2026-05

Version:

1.0.0

Project Overview

An enterprise-grade AI workflow built on n8n that processes:

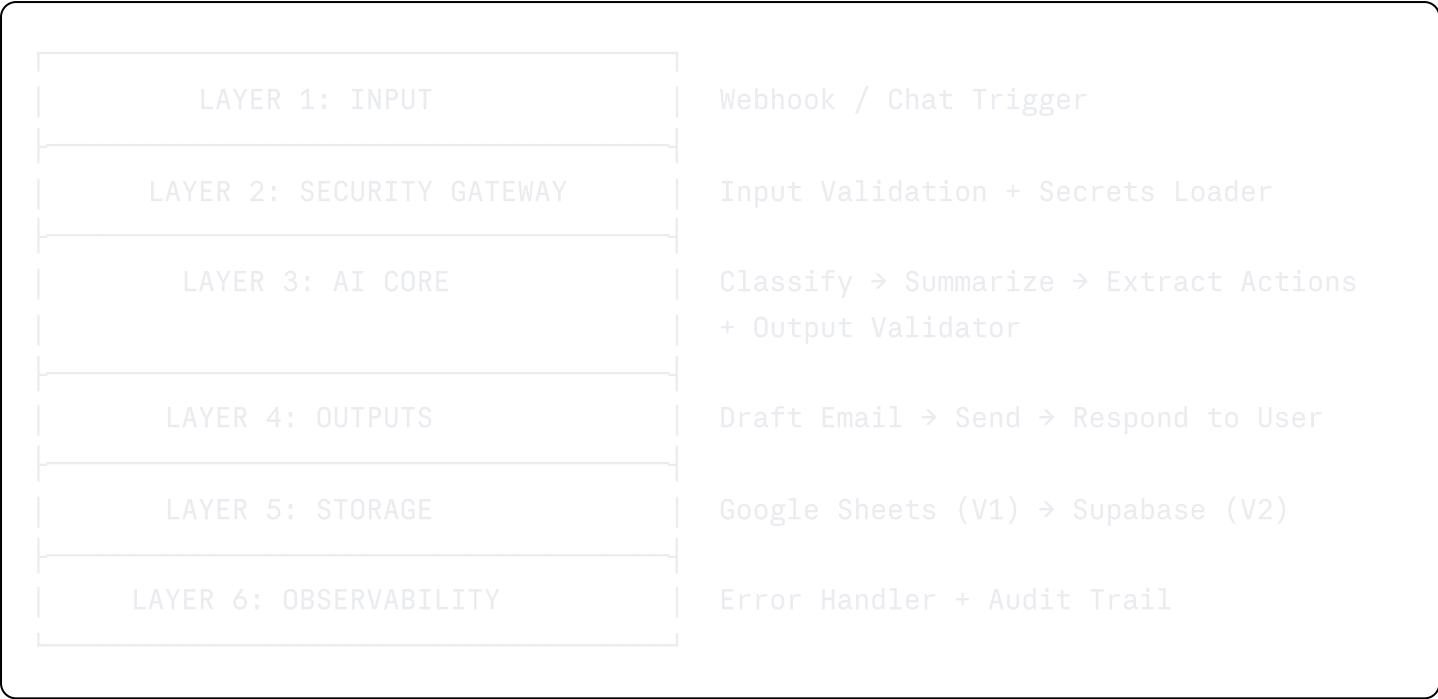
- Security incidents
- Vulnerability findings
- Governance and compliance findings
- Audit findings
- SSP (System Security Plan) findings
- Vendor responses
- Patching updates
- Operational tickets

The system receives unstructured text input, classifies severity, summarizes the issue, extracts action items, drafts a professional email response, and stores all results to a database — in a modular, scalable, and auditable pipeline.

Goals

Goal	Description
Simplicity	V1 is intentionally minimal. Build, learn, iterate.
Stability	Every node has error handling. No silent failures.
Scalability	Modular design allows adding input types and output channels without breaking existing flows.
Auditability	Every run is logged. Immutable audit trail from Day 1.
Security-first	No hardcoded secrets. Input sanitized before AI. Output validated before action.

System Layers



Implementation Roadmap

Phase 1 — Foundation

Branch: `phase-1-foundation`

Goal: Stable entry point with security gateway.

- ☒ Install and run n8n
- ☒ Create GitHub repo with README and .gitignore
- ☐ Create `ARCHITECTURE.md` (this file)
- ☐ Configure environment variables in n8n
- ☐ Build Webhook trigger node — confirm 200 OK response
- ☐ Build Input Validator node (sanitize, length check, injection guard)
- ☐ Commit and push to `phase-1-foundation` branch

Exit criteria: Webhook receives input, validates it, returns a clean response. Nothing breaks on bad input.

Phase 2 — AI Core

Branch: `phase-2-ai-core`

Goal: AI classification, summarization, and action extraction working end-to-end.

- ☐ Connect OpenAI or Anthropic API credentials in n8n
- ☐ Build AI Classify node with `prompts/classify-v1.txt`
- ☐ Build AI Summarize node with `prompts/summarize-v1.txt`

- ☐ Build AI Extract Actions node with `prompts/extract-actions-v1.txt`
- ☐ Build Output Validator node (schema check + confidence gate)
- ☐ Build fallback handler for invalid or low-confidence AI output
- ☐ Test with all 8 input types (see `/tests/`)
- ☐ Commit prompts to version control separately

Exit criteria: Input goes in → structured JSON with severity, summary, and action items comes out. Invalid AI responses are caught and flagged.

Phase 3 — Outputs & Storage

Branch: `phase-3-outputs`

Goal: Results stored, email sent, user receives a response.

- ☐ Build AI Draft Email node with `prompts/draft-email-v1.txt`
- ☐ Connect Gmail or SMTP node
- ☐ Create Google Sheet with correct columns (see schema below)
- ☐ Build Append Row node to write results
- ☐ Build Respond to Webhook node (return JSON to caller)
- ☐ End-to-end test: input → email sent → row in Sheets → response returned

Exit criteria: Full pipeline runs without manual intervention. Every result is stored. Emails are sent for HIGH and CRITICAL findings.

Phase 4 — Hardening

Branch: `phase-4-hardening`

Goal: Production-ready reliability and security.

- ☐ Add Error Trigger sub-workflow
- ☐ Add retry logic (3x with 2s delay) on all AI nodes
- ☐ Add audit log tab in Google Sheets
- ☐ Add webhook secret header validation (`X-Webhook-Secret`)
- ☐ Write test payload for each of the 8 input types
- ☐ Final documentation pass

Exit criteria: System handles failures gracefully. All inputs tested. Audit trail in place. No secrets exposed.

Folder Structure

```
ai-governance-assistant/
```

```
|
|
| — .env.example          ← Secrets template (never commit .env)
| — .gitignore
| — README.md
| — ARCHITECTURE.md      ← This file
|
| — workflows/
|   | — v1-main-workflow.json    ← n8n workflow export
|   | — v1-error-handler.json   ← Error sub-workflow export
|   | — v1-test-payloads.json   ← Test inputs
|
| — prompts/
|   | — classify-v1.txt
|   | — summarize-v1.txt
|   | — extract-actions-v1.txt
|   | — draft-email-v1.txt
|
| — docs/
|   | — node-guide.md          ← Node-by-node explanation
|   | — schema.md             ← Storage schema
|
| — tests/
|   | — sample-incident.txt
|   | — sample-vulnerability.txt
|   | — sample-audit-finding.txt
|   | — sample-governance.txt
|   | — sample-ssp.txt
|   | — sample-vendor.txt
|   | — sample-patch.txt
|   | — sample-ticket.txt
```

Storage Schema — Google Sheets (V1)

Column	Type	Description
run_id	string	UUID generated per run
timestamp	datetime	UTC timestamp of processing
input_type	string	incident / vulnerability / audit / etc.
severity	string	CRITICAL / HIGH / MEDIUM / LOW / INFO
confidence	float	AI confidence score (0.0-1.0)

Column	Type	Description
<code>summary</code>	string	2-3 sentence AI summary
<code>action_count</code>	integer	Number of extracted action items
<code>email_sent</code>	boolean	Whether email was sent
<code>error_flag</code>	boolean	Whether this run had any errors
<code>escalation_required</code>	boolean	From AI output

AI Prompt Versions

Prompt file	Version	Purpose
<code>classify-v1.txt</code>	1.0	Classify type, severity, confidence
<code>summarize-v1.txt</code>	1.0	2-3 sentence factual summary
<code>extract-actions-v1.txt</code>	1.0	Structured action item extraction
<code>draft-email-v1.txt</code>	1.0	Professional response email

Prompt changes must be committed with a new version suffix (e.g. `classify-v2.txt`) and a note in the commit message explaining what changed and why.

Security Decisions

Risk	Decision	Reason
Prompt injection	Strip HTML and limit input to 4000 chars before passing to AI	Malicious input should never reach the model raw
Hardcoded API keys	All credentials via n8n Credentials panel only	Prevents secrets appearing in exports or logs
System prompt exposure	Never return prompt contents in API responses	Internal architecture stays internal
Unvalidated AI output	Output validator runs before any action	AI can hallucinate; we don't act on unvalidated output

Risk	Decision	Reason
Unrestricted webhook	X-Webhook-Secret header check (Phase 4)	Prevents anyone on the internet from triggering runs

Architecture Decision Log

Date	Decision	Reason	Tradeoff
2026-05	Google Sheets for V1 storage	Zero setup cost, visual demo, fast to build	Not suitable for production scale; migrate to Supabase in V2
2026-05	One repo, phase branches	Single system, easier to trace history	Would separate repos if these were independent services
2026-05	Separate prompts from workflow	Prompts change independently from logic	Requires discipline to keep in sync
2026-05	Output validator before all actions	AI output is never blindly trusted	Adds one extra node; worth it always

Future Expansion (V2 and V3)

Version 2:

- Supabase (PostgreSQL) instead of Google Sheets
- Slack alerts for CRITICAL severity
- Input type auto-routing via Switch node (8 separate sub-workflows)
- Confidence threshold gate (below 0.6 → human review queue)
- RAG layer using T1N0 governance documentation

Version 3:

- JWT or API key authentication on webhook
- Role-based alert routing
- Grafana or Metabase dashboard on Supabase
- Local AI model via Ollama (for sensitive data that cannot leave the network)
- HMAC webhook signature verification

This document should be updated at the end of every phase.